BPFDOOR-DEFENSE

BPFDoor 백도어와 리눅스 탐지

연관 기출 · 137-4-1

한눈에 이해

열린 수신 포트만 확인하면 대기 중인 백도어를 놓칠 수 있습니다. 프로세스·소켓·패킷·파일의 흔적을 함께 확인합니다.

정의와 핵심 원리

BPFDoor는 리눅스의 BPF 기반 패킷 필터 등을 악용하여 특정 네트워크 트래픽을 감시하고 명령·후속 연결을 활성화하는 백도어 계열로 알려져 있습니다. 정상 BPF 사용과 악성 사용을 구분해야 합니다.

• 고정 포트에서 연결을 기다리는 백도어와 달리, 눈에 띄는 수신 포트 없이도 트리거 패킷을 감시할 수 있습니다. 따라서 포트 스캔 결과 하나로 감염 없음을 보장할 수 없습니다. 변종별 프로세스 위장·지속성·통신 동작은 다를 수 있습니다.

• 위협은 서버 명령 실행·자격 증명 및 정보 탈취·측면 이동·서비스 가용성 훼손입니다. 관리자 권한·raw socket·BPF 관련 사용과 예상 외 실행 파일·삭제된 실행 파일·비정상 통신·지속성 설정을 조합해 조사하고 정상 운영 도구와 구별합니다.

• 대응은 자산과 공식 점검 범위 확인 → 의심 호스트 격리 → 휘발성·디스크·로그 증거 보존 → 감염·침입 경로 파악 → 비밀·세션 회수 → 깨끗한 재구축·취약점 제거 → 재검증입니다. 일괄 삭제·재부팅으로 증거를 잃거나 원격 접속을 영구 상실하지 않도록 업무 복구와 연계합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
고정 포트 대기형	고정 연결 대기 흔적	포트·소켓 관측
패킷 트리거형	특정 패킷을 감지한 뒤 활성화	포트 검사 외 증거 필요
다층 조사	프로세스·파일·네트워크	시간·변종·오탐 검증

적용 예제

포트가 정상인 의심 서버

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 이상 외부 통신을 관찰했습니다. 평소 포트 목록과 비교했을 때 차이는 없습니다.

1. 공식 가이드와 서버 역할을 대조해 의심 증거를 보존합니다.
2. 실행 경로·권한·소켓·프로세스 관계를 분석합니다.
3. 동일 계정과 인접 서버의 원격 접근 이력을 추적합니다.
4. 공격자가 남긴 재실행 수단과 최초 침입 원인을 제거한 뒤 복구합니다.

결과·해석: 단일 IOC나 포트 검사보다 다층 증거와 원인 제거로 대응합니다.

전제·주의: KISA의 2025-05-12 공지를 열람했습니다. 첨부 가이드 전문과 변종별 IOC는 확인이 남아 있습니다.

답안 골격과 혼동 방지

정상 기능과 악용 구분 → 기존 백도어와 비교 → 위협 영향 → 기술·관리 대응 → 증거·복구

- 모든 BPF 프로세스를 악성으로 분류하지 않습니다.
- 점검 스크립트에 탐지 결과가 없어도 감염 여부는 다른 증거와 함께 판단합니다.

내용을 가리고 회상

1. 수신 포트 없음이 감염 없음을 뜻하지 않는 이유는 무엇입니까?
2. 정상 BPF와 악성 활동을 어떻게 구분합니까?
3. 격리 전후 증거 보존의 우선순위는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- BPFDoor 악성코드 점검 가이드 공지 - KISA KrCERT/CC; 2025-05-12; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.
- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.